DIGITAL COMMERCE SYSTEM

E-COMMERCE

Enterprise Blueprint

Spesifikasi produk, bisnis, pengalaman pengguna, arsitektur, data, keamanan, integrasi, pengujian, dan rencana implementasi untuk platform e-commerce yang siap dikembangkan.

DOKUMEN	DETAIL
Jenis	Product Requirements + Technical Blueprint
Model awal	Single-merchant B2C e-commerce; dapat diperluas ke omnichannel
Pasar awal	Indonesia; mata uang utama IDR
Versi / tanggal	1.0 / 9 Oktober 2026
Status	Baseline spesifikasi untuk discovery, estimasi, desain, dan implementasi

Catatan: dokumen ini adalah blueprint rekayasa dan produk, bukan opini hukum, bukan perjanjian dengan penyedia pembayaran, dan bukan jaminan kepatuhan otomatis.

Cara menggunakan dokumen ini

Gunakan dokumen ini sebagai baseline persyaratan. Setiap item berprioritas P0 perlu diterjemahkan menjadi user story, desain, implementasi, pengujian, dan bukti penerimaan. Jangan menganggap fitur selesai hanya karena halaman UI sudah tersedia.

Konvensi	Makna
P0 - wajib	Tanpa ini transaksi, keamanan, atau operasi inti tidak dapat berjalan dengan aman.
P1 - penting	Meningkatkan efisiensi, kontrol, retensi, atau kesiapan operasi setelah fondasi stabil.
P2 - lanjutan	Fitur diferensiasi atau ekspansi; implementasikan setelah nilai dan kebutuhan terukur.
MUST / SHOULD / MAY	MUST adalah kebutuhan wajib untuk ruang lingkup ini; SHOULD prioritas tinggi; MAY opsional.
AC (acceptance criteria)	Kondisi yang harus dapat dibuktikan melalui pengujian, bukan interpretasi visual.
MVP	Rilis minimum yang benar-benar dapat menjual, memproses pembayaran, mengirim pesanan, dan menangani masalah.

Batasan dan asumsi yang dipakai

- Model utama adalah toko online milik satu badan usaha yang menjual produk sendiri; bukan marketplace multi-seller pada fase awal.
- Fokus awal adalah barang fisik di Indonesia, checkout guest dan akun terdaftar, pengiriman domestik, serta tampilan mobile-first.
- Pembayaran diproses oleh penyedia berizin/bermitra sesuai aturan yang berlaku; platform tidak menyimpan data kartu mentah.
- Satu storefront dan satu merek pada MVP. Multi-warehouse dan multi-brand disiapkan secara desain, tetapi dapat ditunda sampai kebutuhan operasional membenarkannya.
- Integrasi pihak ketiga harus menggunakan sandbox, kontrak API, dan prosedur rekonsiliasi; ketersediaan integrasi bergantung pada vendor yang dipilih.
- Estimasi dan target operasional dalam dokumen ini bersifat baseline perencanaan yang perlu divalidasi lewat discovery, traffic forecast, serta SLA vendor.

Daftar isi / peta dokumen

Bagian	Topik
01	Ringkasan eksekutif dan definisi produk
02	Tujuan bisnis, KPI, dan batas lingkup
03	Pengguna, peran, dan hak akses
04	Sitemap dan spesifikasi halaman storefront
05	Persyaratan fungsional storefront
06	Commerce core: checkout, pembayaran, pesanan
07	Inventaris, fulfillment, pengiriman, retur
08	Admin center dan back-office operations
09	Workflow, state machine, dan aturan bisnis
10	Arsitektur aplikasi dan keputusan teknis
11	API, event, integrasi, dan idempotensi
12	Model data dan aturan integritas
13	Keamanan, privasi, dan kepatuhan Indonesia
14	Non-functional requirements dan SLO
15	SEO, aksesibilitas, dan kualitas UX
16	Analytics, event taxonomy, dan reporting
17	Strategi testing dan acceptance criteria
18	Deployment, observability, backup, dan operasi
19	Roadmap implementasi dan tim
20	Risiko utama dan mitigasi
21	Go-live checklist dan definisi selesai
22	Glosarium dan referensi resmi

01. Ringkasan eksekutif dan definisi produk

Platform yang dituju adalah toko digital yang tidak hanya menampilkan katalog, tetapi mengelola satu siklus dagang penuh: discovery produk, penghitungan harga, ketersediaan stok, checkout, pembayaran, pemenuhan pesanan, pengiriman, layanan pelanggan, retur, dan analitik.

1.1 Definisi produk

Produk terdiri dari empat permukaan yang menggunakan domain data dan aturan bisnis bersama:

Permukaan	Pengguna	Tujuan utama
Storefront publik	Pengunjung dan pembeli	Menemukan produk, mengevaluasi penawaran, melakukan pembelian, dan mencari bantuan.
Customer account	Pembeli terdaftar	Melihat histori pesanan, alamat, pengiriman, invoice/dokumen, wishlist, dan retur.
Admin / operations	Customer service, katalog, gudang, finance, marketing	Mengelola produk, stok, order, refund, konten, promosi, dan pengecualian.
Management / analytics	Pemilik, manajer, analis	Memantau penjualan, konversi, margin bila datanya tersedia, stok, SLA, refund, dan risiko.

1.2 Prinsip desain

- Trust first: harga, total biaya, stok, jadwal pengiriman, kebijakan retur, dan status pembayaran harus jelas sebelum pengguna berkomitmen.
- Server is authoritative: browser tidak boleh menentukan harga final, diskon final, jumlah stok, status pembayaran, atau hak akses.
- Safe failure: webhook duplikat, pembayaran terlambat, pengiriman gagal, dan job yang diulang harus menghasilkan kondisi yang konsisten.
- Auditability: perubahan penting pada produk, harga, stok, order, refund, hak akses, dan konfigurasi harus dapat ditelusuri.
- Mobile-first: alur inti dirancang untuk layar kecil, koneksi tidak stabil, dan input minimal.
- Modular but not overengineered: modul dipisahkan secara logis; tidak membuat microservices hanya demi terlihat kompleks.

1.3 Model operasi yang direkomendasikan

Untuk fase awal, gunakan model single-merchant B2C dengan katalog terpusat, satu mata uang, satu kanal storefront, satu sistem order, dan integrasi eksternal melalui adaptor. Siapkan extension points untuk multi-warehouse, B2B pricing, loyalty, subscriptions, marketplace, dan omnichannel, tetapi jangan mengimplementasikan seluruhnya sebelum ada kebutuhan yang terbukti.

> **Keputusan scope utama**
>
> Jangan memulai sebagai marketplace kecuali bisnis benar-benar menampung penjual pihak ketiga. Marketplace menambahkan onboarding seller, settlement, komisi, sengketa seller, katalog multi-sumber, split order, pajak/kontrak seller, dan risiko regulasi yang jauh lebih besar.

02. Tujuan bisnis, KPI, dan batas lingkup

Setiap modul harus mempunyai alasan bisnis dan ukuran hasil. KPI di bawah adalah target awal yang harus divalidasi dengan baseline setelah analytics berjalan.

2.1 Hasil bisnis

ID	Hasil yang dituju	Metrik awal	Catatan
BIZ-01	Meningkatkan pembelian yang berhasil	Conversion rate, checkout completion	Pisahkan traffic paid, organic, direct, dan returning.
BIZ-02	Mengurangi kegagalan transaksi	Payment success rate, duplicate order rate	Bedakan kegagalan user, issuer, vendor, dan sistem.
BIZ-03	Memenuhi janji stok dan pengiriman	Oversell rate, dispatch SLA, cancellation rate	Gunakan definisi cut-off dan kalender operasional.
BIZ-04	Meningkatkan repeat purchase	Repeat purchase rate, cohort retention	Jangan menganggap email terkirim sama dengan retensi.
BIZ-05	Mengurangi beban support	Ticket rate per 100 orders, first response time	Tag alasan kontak secara konsisten.
BIZ-06	Meningkatkan margin operasional	Gross margin jika cost tersedia, promo leakage	Pendapatan bukan laba; biaya produk, subsidi kirim, dan fee perlu dihitung.

2.2 Target teknis awal

Metrik	Baseline yang disarankan	Cara verifikasi
Core Web Vitals	LCP <= 2.5 s, INP < 200 ms, CLS < 0.1 untuk persentil ke-75	Field data dari perangkat nyata + synthetic checks.
Storefront availability	99.9% bulanan sebagai sasaran awal bila biaya operasi mengizinkan	Synthetic checks; pisahkan downtime vendor pembayaran.
API read latency	p95 < 400 ms untuk endpoint internal yang sederhana	Load test dengan dataset dan pola cache realistis.
API write latency	p95 < 700 ms untuk operasi internal non-provider	Jangan memasukkan waktu tunggu provider ke angka ini.
Recovery Point Objective	<= 24 jam untuk baseline; target lebih ketat jika risiko bisnis menuntut	Bukti restore backup, bukan hanya status backup hijau.
Recovery Time Objective	<= 8 jam untuk baseline MVP	Latihan pemulihan dan runbook yang benar-benar dicoba.

Target performa Core Web Vitals selaras dengan panduan Google Search Central; target ketersediaan dan pemulihan di tabel adalah rekomendasi desain, bukan standar legal atau jaminan provider. [R7]

2.3 Scope MVP (P0)

- Katalog, kategori, pencarian dasar, halaman produk, varian, harga, stok, kebijakan pengiriman dan retur.
- Keranjang persisten, checkout guest, alamat, pilihan pengiriman, kode promo sederhana, dan total biaya yang server-calculated.
- Payment provider hosted checkout/redirect atau tokenized flow, webhook signature verification, dan rekonsiliasi status pembayaran.
- Order management, pick/pack/ship status, nomor resi, email transaksi, pembatalan yang terkontrol, serta workflow retur manual.
- Admin dengan permission berbasis peran untuk katalog, order, inventaris, customer support, promosi, CMS, dan laporan dasar.
- Audit log untuk tindakan sensitif, monitoring error, backup/restore, test suite dasar, deployment staging/production, SEO teknis, dan aksesibilitas inti.

2.4 Di luar MVP (P1/P2)

- Marketplace multi-seller, seller payout/split settlement, dan dispute resolution antar penjual.

- Rekomendasi AI personal, dynamic pricing, advanced loyalty, subscription commerce, BNPL, dan social commerce.
- Aplikasi native mobile terpisah, multi-country tax engine, multi-currency, dan multi-language penuh.
- ERP bidirectional integration, demand forecasting, warehouse optimization, dan data warehouse khusus jika volume belum membenarkan.
- Fraud scoring khusus machine-learning; fase awal gunakan rules, provider tools, rate limits, dan manual review.

03. Pengguna, peran, dan hak akses

Hak akses perlu ditentukan berdasarkan tugas, bukan jabatan semata. Pisahkan fungsi operasional dan persetujuan pada tindakan berisiko tinggi untuk mengurangi kesalahan dan penyalahgunaan.

Peran	Kapabilitas	Larangan / batasan default
Guest shopper	Cari, lihat produk, keranjang, checkout sebagai tamu, lacak order memakai token aman.	Tidak dapat melihat order orang lain; tidak dapat mengubah data order setelah batas tertentu.
Customer	Kelola profil/alamat, lihat order miliknya, ajukan retur, tulis review yang memenuhi aturan.	Tidak dapat melihat customer lain; tidak dapat menyunting status pembayaran.
Catalog editor	Kelola draft produk, atribut, media, kategori, metadata SEO.	Publikasi atau perubahan harga besar dapat memerlukan approval.
Merchandiser / marketing	Promo, kupon, landing campaign, banner, segmentasi yang diizinkan.	Tidak dapat mengubah ledger pembayaran atau memberi refund.
Order operator	Proses, alokasikan, pick/pack, kirim, tangani exception order.	Tidak dapat melakukan refund bernilai tinggi tanpa approval.
Customer support	Cari order, lihat data minimum, balas tiket, mengusulkan pembatalan/retur.	Data sensitif disamarkan; aksi finansial mengikuti approval.
Warehouse operator	Penerimaan, transfer, penyesuaian stok dengan alasan, picking dan packing.	Tidak dapat mengubah harga, data pembayaran, atau kebijakan.
Finance	Verifikasi rekonsiliasi, review refund, ekspor laporan keuangan yang diotorisasi.	Tidak otomatis mendapat akses konfigurasi keamanan.
Manager / approver	Menyetujui diskon, refund, adjustment stok, atau perubahan kebijakan sesuai batas.	Tidak boleh menghapus audit record.
System administrator	Konfigurasi operasional, integrasi, role assignment, tenant/site settings.	Akses istimewa diaudit; akses rutin dengan akun terpisah dari akun admin break-glass.
Auditor / read-only	Melihat log, laporan, konfigurasi dan histori sesuai lingkup.	Tidak melakukan mutation.

3.1 Aturan otorisasi

- Default deny: akses ditolak kecuali diizinkan secara eksplisit.
- Enforce authorization di server untuk setiap read/write; menyembunyikan tombol di UI bukan pengamanan.
- Pisahkan role dari permission granular seperti product.publish, order.refund, inventory.adjust, promotion.approve, user.role.assign.
- Gunakan least privilege, session timeout yang wajar, MFA untuk administrator dan peran berisiko, serta re-authentication untuk aksi sensitif.
- Untuk tindakan finansial atau berisiko, gunakan maker-checker (pengaju berbeda dari penyetuju) dengan ambang nominal yang dapat dikonfigurasi.
- Catat actor, target, perubahan sebelum/sesudah yang relevan, timestamp, alasan, request ID, dan sumber aksi pada audit trail.

04. Sitemap dan spesifikasi halaman storefront

Sitemap ini menjadi kontrak informasi dan routing. Nama URL boleh berubah setelah SEO review, tetapi struktur konten dan kemampuan tidak boleh hilang.

Route / halaman	Tujuan	Komponen utama
/	Menjelaskan proposisi nilai dan mengarahkan ke produk.	Header, kategori utama, hero, kampanye, best sellers, value proposition, trust signals, FAQ ringkas, footer.
/shop atau /products	Menjelajah katalog.	Grid produk, filter, sort, pagination/load more, jumlah hasil, empty state.
/category/[slug]	Menjelajah kategori.	Breadcrumb, deskripsi kategori, child categories, filter sesuai atribut, sort.
/product/[slug]	Evaluasi dan beli produk.	Galeri, harga, varian, stok, quantity, estimasi pengiriman, CTA, spesifikasi, ulasan, retur/pengiriman.
/search?q=	Hasil pencarian.	Autocomplete opsional, hasil, query correction, filter, popular searches, empty state.
/cart	Review item sebelum checkout.	Foto, varian, kuantitas, harga item, stok, promo, estimasi subtotal, update/remove, cross-sell opsional.
/checkout	Menyelesaikan pembelian.	Contact, address, shipping method, order summary, promo, payment method, terms, error recovery.
/order/confirmation	Konfirmasi order.	Order number, status pembayaran, ringkasan, instruksi berikutnya, link order tracking.
/track-order	Pelacakan mandiri.	Order reference + verifikasi aman, status shipment, kurir/resi, langkah support.
/account/*	Area pelanggan.	Overview, orders, order detail, addresses, profile, returns, wishlist, privacy controls.
/help /faq	Mengurangi hambatan dan tiket support.	Top questions, search, shipping/return/payment policies, contact form, ticket status.
/shipping-policy, /returns, /privacy, /terms	Transparansi kebijakan.	Bahasa jelas, tanggal berlaku, kontak, versi kebijakan, persetujuan bila relevan.
/about /contact	Kepercayaan dan informasi merchant.	Identitas usaha, alamat/kontak yang relevan, jam operasional, kanal layanan.
/blog /guides	Akuisisi organik dan edukasi.	Artikel terstruktur, author/editor, kategori, internal links, related products.

4.1 Standar lintas halaman

- Semua halaman harus memiliki loading, error, empty, offline/timeout bila relevan, dan success states yang didesain eksplisit.
- Gunakan design system: spacing, typography, color, buttons, inputs, alerts, badges, dialogs, toasts, skeletons, tables, and responsive breakpoints.
- Tampilkan state stok dan harga secara konsisten; jangan menampilkan harga/stock dari cache yang diketahui sudah kedaluwarsa tanpa indikasi atau validasi server.
- URL produk dan kategori harus stabil, dapat dibagikan, memiliki canonical, dan menangani perubahan slug dengan redirect yang aman.
- Konten kebijakan mudah ditemukan sebelum checkout dan dari footer; persetujuan yang dibutuhkan disimpan dengan versi dan timestamp.

05. Persyaratan fungsional storefront

Persyaratan di bawah ditulis sebagai perilaku sistem yang harus diuji. Setiap item perlu memiliki unit/integration/e2e tests yang sepadan berdasarkan risiko.

5.1 Katalog, produk, kategori, dan varian

ID	Requirement	Priority	Acceptance criteria minimum
CAT-01	Produk mempunyai SKU stabil, slug, nama, deskripsi, status, kategori, atribut, media, SEO, dan timestamps.	P0	Produk draft tidak muncul publik; SKU unik sesuai kebijakan.
CAT-02	Produk mendukung varian seperti ukuran/warna dengan SKU dan stok per varian.	P0	Memilih varian mengubah harga/stok/media yang relevan secara konsisten.
CAT-03	Media memiliki alt text, urutan, thumbnail, optimasi ukuran dan format.	P0	Gambar tidak memaksa layout bergeser; alt text dapat diisi editor.
CAT-04	Harga, harga coret, tax treatment, unit, dan mata uang dikelola terstruktur.	P0	Harga final di checkout dibaca/dihitung server; perubahan harga tidak mengubah order historis.
CAT-05	Produk dapat diarsipkan tanpa merusak histori pesanan.	P0	Order lama tetap menampilkan snapshot nama, varian, dan harga yang dibeli.
CAT-06	Atribut produk dapat dikonfigurasi per kategori.	P1	Filter hanya muncul bila atribut relevan dan memiliki data.
CAT-07	Bulk import/export dengan preview, validasi, error report, dan idempotent key.	P1	Baris valid dapat diproses sesuai kebijakan; baris invalid dilaporkan tanpa silent failure.
CAT-08	Bundle/kits dan produk digital dapat ditambahkan sebagai tipe terpisah.	P2	Aturan stok, fulfilment, dan refund didefinisikan sebelum release tipe baru.

5.2 Pencarian dan discovery

- P0: cari nama, SKU publik yang memang boleh dicari, kategori, dan atribut dasar; urutkan berdasarkan relevansi, terbaru, harga naik/turun, dan popularitas yang didefinisikan.
- P0: filter harus tercermin pada state URL agar dapat dibagikan dan tombol back browser bekerja secara wajar.
- P0: pencarian kosong dan pencarian tanpa hasil menunjukkan saran kategori/produk alternatif tanpa mengarang produk yang tidak ada.
- P1: typo tolerance, synonyms, autocomplete, query analytics, boost rules, dan merchandising manual.
- P2: search service terpisah hanya ketika volume, relevansi, bahasa, atau kebutuhan faceting melampaui kemampuan pencarian database.

5.3 Keranjang

- P0: support guest cart dan cart terikat akun; merge cart setelah login dengan aturan konflik yang jelas.
- P0: validasi kuantitas terhadap aturan pembelian dan stok; server mengembalikan jumlah yang dapat dibeli.
- P0: simpan varian, kuantitas, dan waktu update; jangan mempercayai harga yang dikirim klien.
- P0: hapus item, ubah kuantitas, apply/remove coupon, lihat estimasi subtotal dan ongkir bila tersedia.
- P0: keranjang tidak menjamin reservasi stok kecuali sistem secara eksplisit menerapkan reservation TTL.
- P1: abandoned cart events dan reminder dengan consent/policy yang sesuai; jangan mengirim marketing email tanpa dasar yang tepat.

5.4 Akun pelanggan

- P0: daftar/login melalui pola yang aman; opsi guest checkout tetap tersedia untuk mengurangi friction.
- P0: email verification atau mekanisme verifikasi yang sesuai, reset password melalui token sekali pakai, rate limits, serta anti-enumeration.
- P0: pelanggan dapat melihat order hanya setelah otorisasi atau validasi token tracking yang tidak mudah ditebak.
- P0: pengelolaan alamat dengan satu alamat default opsional, validasi field sesuai cakupan pengiriman, dan pembatasan data yang ditampilkan.
- P1: social sign-in, passkeys, saved payment token yang dikelola provider, loyalty, serta personalisasi setelah privacy review.

5.5 Review, rating, wishlist

- P1: pembeli terverifikasi dapat membuat review hanya untuk produk yang memenuhi kebijakan eligibility.
- P1: sistem menangani moderation state: pending, published, rejected, hidden; alasan moderasi tercatat.
- P1: tandai ulasan pembelian terverifikasi secara jujur; jangan mengubah atau memalsukan rating.
- P1: wishlist persisten dan dapat dipindahkan ke cart setelah stok/harga divalidasi ulang.
- P2: foto/video review, helpful votes, Q&A produk, dan anti-spam yang tidak menghalangi pengguna sah secara berlebihan.

06. Commerce core: checkout, pembayaran, dan pesanan

Checkout adalah area dengan risiko finansial terbesar. Total final, status order, dan status pembayaran harus memiliki satu sumber kebenaran di server serta dicatat secara auditabel.

6.1 Checkout dan total order

Komponen	Aturan wajib
Customer data	Minta data minimum untuk transaksi/pengiriman; validasi alamat, kontak, dan field yang diperlukan.
Address snapshot	Simpan snapshot alamat penerima di order agar perubahan alamat profil tidak menulis ulang order historis.
Shipping quote	Quote memiliki provider/service, price, estimasi/terms, expiration time bila vendor mensyaratkan, dan hasil validasi.
Pricing snapshot	Simpan unit price, quantity, discount allocation, subtotal, shipping, tax/fee bila berlaku, grand total, currency, dan aturan pembulatan.
Promo validation	Validasi eligibility, periode, minimum spend, item/kategori, usage limit, stacking, dan batas per customer di server.
Inventory check	Periksa stok ulang ketika order dibuat; gunakan transaksi database/atomic reservation agar dua checkout tidak menjual stok sama.
Order confirmation	Order dibuat dengan status pending payment/awaiting confirmation yang eksplisit; jangan menyatakan paid sebelum verifikasi.
Idempotency	Create-order dan create-payment-intent menerima idempotency key sehingga retry tidak membuat order/pembayaran ganda.
Terms consent	Simpan policy version, timestamp, dan event persetujuan yang relevan; pisahkan consent marketing dari acceptance transaksi.

6.2 Payment lifecycle

Gunakan payment adapter untuk mengisolasi perbedaan provider. Backend menyimpan internal payment attempt ID dan reference provider, tetapi data sensitif kartu tetap pada provider jika menggunakan hosted/tokenized checkout.

State	Makna	Aksi yang diizinkan
created	Payment attempt dibuat secara internal.	Redirect/submit kepada provider; timeout dapat ditangani dengan retry aman.
pending	Menunggu hasil provider/pelanggan.	Tunggu webhook atau lakukan server-side status inquiry.
requires_action	Pelanggan perlu menyelesaikan langkah lanjutan.	Tampilkan instruksi/redirect aman; jangan mengubah menjadi paid di klien.
succeeded	Provider mengonfirmasi berhasil dan signature/identitas event terverifikasi.	Catat paid_at; release fulfilment sesuai policy.
failed	Provider menyatakan gagal terminal.	Izinkan metode bayar baru sesuai aturan; jangan hapus audit.

State	Makna	Aksi yang diizinkan
expired/cancelled	Attempt tidak lagi dapat digunakan.	Tutup attempt lama; order mengikuti timeout/cancellation policy.
refunded / partially_refunded	Refund terkonfirmasi, bisa sebagian.	Update refund ledger dan order fulfillment sesuai jumlah/kebijakan.

6.3 Pembayaran: kontrol dan rekonsiliasi

- Verifikasi webhook signature, event ID, timestamp bila provider menyediakan, dan kaitan ke internal payment attempt.
- Simpan raw event yang diperlukan untuk audit dengan retensi terbatas dan redaksi; jangan menyimpan secret atau data kartu.
- Tahan duplikat webhook dengan unique constraint pada provider + event ID; proses event dalam transaksi yang aman.
- Jangan bergantung hanya pada return URL browser: browser kembali tidak membuktikan pembayaran berhasil.
- Jika event hilang/terlambat, status inquiry dan rekonsiliasi berkala memperbaiki kondisi tanpa menciptakan charge/order ganda.
- Refund menggunakan lifecycle tersendiri: requested, approved, submitted, pending, succeeded/failed; jangan memberi label refunded sebelum konfirmasi provider.
- Buat antrean exception untuk mismatch amount/currency, payment tanpa order, order paid tanpa payment, dan refund yang menggantung.

6.4 Order management

- Order number yang dapat dibaca manusia terpisah dari internal UUID/ID dan tidak boleh menjadi satu-satunya rahasia akses.
- Order menyimpan snapshot line items, alamat, harga, pajak/fee, metode pengiriman, kebijakan, dan sumber kampanye pada saat transaksi.
- Perubahan status menggunakan perintah/command yang memvalidasi transisi, permission aktor, dan prasyarat; hindari edit status bebas.
- Pembatalan sebelum dispatch dapat otomatis bila tidak ada constraint; setelah picking/shipping memerlukan workflow berbeda.
- Order amendments setelah pembayaran harus didefinisikan terpisah; jangan mengubah total transaksi historis tanpa ledger adjustment/refund yang jelas.
- Sediakan internal notes dan customer-visible timeline terpisah. Jangan bocorkan catatan internal kepada pelanggan.

07. Inventaris, fulfillment, pengiriman, dan retur

Persediaan dan fulfillment menentukan apakah sistem benar-benar beroperasi. Stok harus berupa ledger/perubahan yang dapat ditelusuri, bukan sekadar angka yang diedit manual tanpa alasan.

7.1 Inventory

Aturan	Implementasi yang diharapkan
Stock by SKU/location	On-hand, reserved, allocated, available, damaged, and safety stock dipisahkan secara jelas.
Reservation	Reservasi saat order/payment flow yang dipilih, dengan TTL dan job expiry yang aman; jangan mengunci stok selamanya.
Atomicity	Gunakan transaksi/conditional update/row lock untuk mencegah oversell saat checkout paralel.
Adjustment	Adjustment membutuhkan quantity delta, alasan terstandardisasi, aktor, sumber referensi, dan approval sesuai ambang.
Movement ledger	Catat receipt, reserve, release, pick, ship, return-to-stock, damage, transfer, dan correction.
Safety stock	Dapat dikonfigurasi per SKU/lokasi untuk melindungi stok offline atau buffer operasional.
Reconciliation	Lakukan cycle count dan rekonsiliasi sistem-vs-fisik dengan variance report.

7.2 Fulfillment dan shipping

- P0: order yang siap diproses masuk ke fulfillment queue setelah status pembayaran/approval memenuhi aturan.
- P0: picking list menampilkan SKU, varian, qty, bin/location jika tersedia, dan order reference.
- P0: packing/dispatch mencatat siapa, kapan, carrier/service, tracking number, jumlah paket, dan shipping label reference jika ada.
- P0: status tracking dari provider dipetakan ke internal states tanpa menurunkan status secara keliru ketika event datang tidak berurutan.
- P0: pelanggan mendapat notifikasi pada milestone penting dan halaman tracking menampilkan data secukupnya.
- P1: multi-package, split fulfillment per lokasi, click-and-collect, shipping insurance, dan delivery exception workflows.
- P1: integrasi kurir memiliki timeout, retry, rate-limit handling, fallback manual, dan reconciliation terhadap shipment yang tidak sinkron.

7.3 Return, refund, exchange

Tahap	Aturan dan kontrol
Request	Pelanggan memilih line item, qty, alasan, deskripsi/foto opsional, dan metode penyelesaian yang tersedia.
Eligibility	Validasi tanggal pembelian, kondisi produk, kategori yang dikecualikan jika sah, status delivery, dan policy version.
Review	CS meninjau; approval diperlukan berdasarkan alasan, nilai, dan risiko. Simpan alasan keputusan.
Return logistics	Buat return authorization, instruksi, label/referensi pengiriman balik, dan batas waktu.
Inspection	Catat kondisi barang diterima, qty diterima, evidence dan hasil pemeriksaan.
Resolution	Refund, exchange, store credit atau penolakan sesuai kebijakan yang dikomunikasikan.
Restock	Barang dapat masuk stok jual hanya setelah pemeriksaan; rusak/cacat ditandai tidak dapat dijual.
Audit	Relasikan return ke order line, payment/refund, aktor, dan customer communication.

08. Admin center dan back-office operations

Admin center harus menjadi control plane operasional, bukan kumpulan halaman CRUD tanpa validasi, histori, dan alur persetujuan.

Modul	Kapabilitas wajib	Kontrol matang
Overview dashboard	Order hari ini, pendapatan terkonfirmasi, pending payment, unfulfilled orders, low stock, returns, ticket backlog.	Filter waktu; definisi KPI; timezone; permission; indikator freshness data.
Product manager	Create/edit/draft/publish/archive, variant matrix, media, category, attributes, SEO.	Preview, revision, approval pada harga/perubahan besar, import validation.
Pricing & promotions	Coupon, automatic discount, campaign window, min spend, eligibility, usage caps.	Stacking policy, budget cap, usage ledger, approval, timezone boundaries.
Inventory & warehouse	Stock balance, receipts, adjustments, transfers, reservations, counts.	Ledger, reason codes, negative-stock policy, dual approval for sensitive changes.
Order desk	Search order, payment timeline, fulfilment, cancellation, returns, internal notes.	State-machine transitions, confirm dialogs, audit log, PII masking.
Finance / payments	Payment attempts, settlement/reconciliation view, refund queue, exceptions.	Separation of duties, idempotent refund, high-value approval.
Customer support	Tickets, customer timeline, order context, canned responses, SLA flags.	Minimum data exposure, no credential visibility, access logging.
CMS / campaign	Pages, banners, editorial workflow, scheduled publish, navigation.	Draft preview, link checks, revision history, safe publish rollback.
Customer management	Profile lookup, order references, consent state, support flags.	No unrestricted bulk export; justification and audit for data export.
User and role management	Users, invitations, roles, permissions, MFA status, sessions.	Least privilege; prevent privilege escalation; alert on admin changes.
Reports / export	Sales, order, inventory, returns, promo, customer cohorts.	Role-based fields, export audit, large exports async, signed download expiration.
Integration settings	Provider status, health, credentials references, webhook failures, retry queue.	Secrets stored outside DB/plain text; restricted admin; rotation history.

8.1 Admin interaction rules

- Setiap halaman data mempunyai search, filter, pagination server-side, loading/error/empty state, dan state permission denied.
- Tindakan destructif atau finansial harus meminta konfirmasi yang menjelaskan dampak; gunakan typed confirmation untuk aksi kritis bila sesuai.
- Bulk action menampilkan jumlah item terpilih, hasil per item, kegagalan parsial, serta opsi retry tanpa menggandakan hasil.
- Admin dapat mencari berdasarkan order ID, external provider reference, SKU, customer reference, atau tracking number sesuai permission.
- Tampilkan timestamp dalam zona waktu yang jelas; database menyimpan timestamp UTC, sedangkan UI menampilkan timezone operasional yang dikonfigurasi.
- Gunakan pagination/filter server-side pada tabel besar; jangan mengunduh seluruh tabel ke browser untuk disaring di klien.

09. Workflow, state machine, dan aturan bisnis

State machine membuat perilaku konsisten di UI, API, job, dan webhook. Status tidak boleh berubah hanya karena komponen frontend memanggil endpoint generik.

9.1 Order lifecycle yang disarankan

draft/cart -> pending_payment -> paid/confirmed -> processing -> partially_fulfilled (bila mendukung split) -> fulfilled/shipped -> delivered -> completed. Jalur samping: payment_failed, cancelled, on_hold, return_requested, partially_returned, returned, partially_refunded, refunded. Status final dan aturan pemulihan harus didefinisikan di satu domain module.

Aturan invariant

Order yang unpaid tidak boleh dilepas ke gudang kecuali model pembayaran/termin mengizinkannya. Order yang sudah delivered tidak boleh langsung berubah menjadi cancelled. Refund tidak boleh melebihi nilai refundable yang telah dihitung setelah refund sebelumnya.

9.2 Contoh aturan transisi

Dari	Ke	Prasyarat minimum	Efek samping
pending_payment	paid	Payment provider terverifikasi; amount/currency/order reference cocok.	Catat paid_at, konfirmasi order, jadwalkan fulfillment event.
pending_payment	cancelled	Batas waktu habis atau pembeli/admin punya alasan sah; tidak ada capture sukses.	Lepaskan reservasi, tutup payment attempt sesuai provider.
paid	processing	Fraud/approval rules lolos; stok tersedia/alokasi valid.	Buat fulfillment task dan picking list.
processing	shipped	Paket dan shipment tercatat; carrier reference tervalidasi.	Kurangi on-hand yang sesuai, update shipment, kirim notifikasi.
delivered	return_requested	Order line eligible sesuai kebijakan.	Buat return case; jangan langsung tambah stok atau refund.
return_approved	refunded	Inspection/policy terpenuhi dan provider menerima refund request.	Catat refund attempt; tunggu konfirmasi untuk final status.

9.3 Kupon dan diskon

- Semua perhitungan dilakukan di server memakai snapshot input: cart lines, customer eligibility, campaign time, usage ledger, dan destination.
- Tetapkan prioritas promosi; secara default satu voucher manual tidak dapat ditumpuk dengan voucher manual lain kecuali aturan menyatakan sebaliknya.
- Tetapkan apakah minimum spend dihitung sebelum/ sesudah diskon item dan apakah ongkir termasuk; dokumentasikan untuk setiap jenis promo.
- Tentukan alokasi diskon per line item agar partial return dapat menghitung nilai refund yang tepat.
- Reserve/redem kupon secara atomik ketika order dibuat/dibayar sesuai kebijakan; release pada cancellation bila aturan mengizinkan.
- Gunakan waktu server yang konsisten dan definisikan zona waktu campaign, termasuk batas awal/akhir yang inklusif atau eksklusif.

9.4 Rounding dan currency

- Gunakan integer minor units untuk uang apabila mata uang/provider mendukung pola itu; hindari floating-point sebagai sumber kebenaran moneter.
- Simpan currency code pada setiap order/payment/refund; jangan berasumsi semua data masa depan selalu IDR.
- Definisikan rounding pada level item, diskon, pajak, fee, ongkir, dan total; semua modul harus memakai fungsi domain yang sama.
- Order menyimpan nilai final snapshot sehingga perubahan katalog atau aturan promo tidak menulis ulang transaksi lama.

10. Arsitektur aplikasi dan keputusan teknis

Rekomendasi awal: modular monolith dengan domain boundaries yang jelas. Struktur ini mempercepat rilis dan menjaga transaksi bisnis lintas modul tetap sederhana; extraction ke service terpisah dilakukan berdasarkan data dan kebutuhan nyata.

10.1 High-level architecture

Layer	Tanggung jawab	Contoh implementasi
Experience	Storefront responsive, account, admin operations.	Next.js App Router, React, TypeScript, Tailwind, design system.
Application/domain	Use cases, validation, pricing, order transitions, permissions.	Server-only modules; domain services; schemas; explicit commands.
Persistence	Transactional records, product/catalog, stock, orders, audit.	PostgreSQL; migrations; constraints; transaction-safe updates.
Identity/storage	Auth lifecycle, user identities, protected product/customer files.	Supabase Auth/Storage atau managed alternative; RLS bila direct access digunakan.
Async processing	Email, webhook events, exports, scheduled expiry, reconciliation.	Managed queue/job runner; durable retry; dead-letter/exception queue.
External integration	Payment, shipping, analytics, email, search/CRM when chosen.	Adapters per vendor; typed contracts; secrets manager; webhook endpoints.
Platform operations	Deploy, secrets, monitoring, backup, restore, incident response.	Managed hosting/CDN, error tracking, logs/metrics/traces, CI/CD.

10.2 Stack awal yang realistis

Area	Rekomendasi awal	Catatan keputusan
Frontend + server	Next.js + TypeScript	SSR/ISR untuk katalog dan SEO; server actions/API route hanya dengan auth, validation, CSRF/origin strategy yang benar.
UI	Tailwind + reusable component library	Bangun token dan pola interaksi sebelum memperbanyak halaman.
Database	PostgreSQL	Source of truth untuk order, inventory, pricing snapshots, and audit.
Auth / storage	Supabase atau layanan terkelola setara	Jangan mengekspos service-role key ke browser; validasi akses server-side.
Search	PostgreSQL full-text awal; service khusus jika perlu	Ukur relevansi dan p95 terlebih dahulu.
Cache	CDN dan cache halaman/data publik selektif	Jangan cache customer-specific pages/stock/checkout tanpa desain invalidation.
Jobs / events	Queue dengan retry durable	Jangan mengandalkan setTimeout di request server untuk tugas penting.
Payment	Provider berizin/kontrak resmi, hosted/tokenized checkout	Periksa metode pembayaran, refund API, webhook, sandbox, settlement dan biaya.
Shipping	Kurir aggregator atau integrasi carrier sesuai operasi	Sediakan fallback manual bila API gagal.
Monitoring	Error tracking + structured logs + uptime checks	Hindari menyertakan token, alamat lengkap, atau data sensitif ke log.

10.3 Domain modules

- Identity & Access: authentication, sessions, roles, permissions, admin safeguards.
- Catalog: product, variant/SKU, category, attributes, media, publication state.
- Pricing & Promotion: price book, eligibility rules, discount calculation, coupon ledger.
- Cart & Checkout: cart state, quote, checkout validation, order creation.

- Order Management: order snapshots, state transitions, cancellations, timeline.
- Payment: attempts, provider references, webhook ingestion, reconciliation, refunds.
- Inventory & Fulfillment: balances, movements, reservations, picking, shipment tracking.
- Customer & Support: customer profile, ticket, return case, communication timeline.
- Content & CMS: pages, campaigns, navigation, SEO fields, revisions.
- Reporting & Audit: domain events, metrics, audit logs, controlled export.

10.4 Architecture principles

- Setiap domain module memiliki kontrak layanan internal; jangan biarkan query lintas modul tersebar di semua komponen UI.
- Validasi pada boundary: request schema, domain rules, database constraints, dan provider response handling.
- Gunakan migration versioned; jangan melakukan perubahan schema produksi secara manual tanpa migration history.
- Pisahkan data operasional transaksional dari analitik berat jika query laporan mengganggu jalur checkout.
- Jangan menambahkan Kafka, Kubernetes, Redis, Elasticsearch, atau microservices kecuali ada bukti kebutuhan dan kemampuan mengoperasikannya.
- Buat data contracts dan ownership untuk field penting seperti status pembayaran, status order, available stock, serta money calculations.

11. API, event, integrasi, dan idempotensi

API harus konsisten, tervalidasi, terdokumentasi, dan dibatasi sesuai role. Untuk sistem internal, kontrak eksplisit dan error model yang stabil lebih penting daripada jumlah endpoint.

11.1 Contoh endpoint boundary

Area	Contoh operasi	Aturan khusus
Catalog	GET /api/products, GET /api/products/{slug}, GET /api/categories	Public read; cacheable bila data tidak personalized; publish state enforced.
Cart	POST /api/cart/items, PATCH /api/cart/items/{id}, DELETE /api/cart/items/{id}	Validasi quantity, variant, max limit, ownership, idempotent updates.
Checkout	POST /api/checkout/quote, POST /api/orders	Recalculate totals server-side; validate shipping quote; idempotency key.
Payment	POST /api/payments/attempts, POST /api/webhooks/payments/{provider}	Webhook authenticated; event deduplication; async process and reconcile.
Orders	GET /api/account/orders, GET /api/admin/orders/{id}, POST /api/admin/orders/{id}/cancel	Customer ownership / admin permissions / state transition guard.
Inventory	POST /api/admin/inventory/adjustments, POST /api/admin/inventory/transfers	Reason required; ledger; approval; no blind overwrite of balance.
Returns	POST /api/orders/{id}/returns, POST /api/admin/returns/{id}/decision	Eligibility, quantity, policy version, evidence and audit.
Admin config	POST /api/admin/users/{id}/roles, PATCH /api/admin/settings	MFA/re-auth for sensitive operations; strict audit and least privilege.

11.2 Error contract

Gunakan satu bentuk error respons (contoh di bawah) dan jangan mengembalikan stack trace, secret, query SQL, atau detail provider sensitif ke klien.

```
{ "error": { "code": "STOCK_INSUFFICIENT", "message": "Jumlah yang diminta tidak tersedia.", "requestId": "...", "details": { "availableQuantity": 2 } } }
```

11.3 Webhook & event processing

- Verifikasi signature memakai raw request body sesuai petunjuk provider; jangan parsing/re-serialize body sebelum verifikasi bila algoritma mengharuskan raw bytes.
- Terima event, verifikasi, simpan envelope minimal dan event ID secara durable, lalu balas 2xx setelah diterima dengan aman; proses domain dapat melalui worker.
- Event duplicate harus menjadi no-op setelah deduplication, sedangkan event out-of-order harus dievaluasi terhadap current state dan provider inquiry.

- Retry menggunakan exponential backoff + jitter; terminal failures masuk dead-letter/exception queue dengan alert dan prosedur replay terkontrol.
- Terapkan idempotency key pada create order, create payment, refund request, shipment label creation, import jobs, dan aksi bulk yang membuat efek eksternal.
- Catat correlation ID/request ID yang menghubungkan browser action, API, job, provider reference, order, dan audit event.

11.4 Integrasi eksternal dan fallback

Integrasi	Data / events	Fallback dan kontrol
Payment provider	Create attempt, status, webhook, refund, settlement report.	Status inquiry, reconciliation, manual exception queue, provider status page.
Shipping/carrier	Quote, create shipment, label, tracking events, cancellation.	Input tracking manual; retry; exception queue untuk state mismatch.
Email/SMS/WhatsApp vendor	Transactional notifications, delivery status bila tersedia.	Outbox retry; templates versioned; alternate channel sesuai consent.
Analytics	Page/product/cart/checkout/order events yang diminimalkan.	Queue/offline buffer; privacy controls; tidak memblokir checkout.
ERP/accounting	Order paid, invoice, stock, refund, settlement reconciliation.	Outbox + import reconciliation; idempotent external reference.
CRM/helpdesk	Customer lead/ticket/order context.	Retry dan dead-letter; minimalkan personal data yang disalin.

12. Model data dan aturan integritas

Model di bawah adalah logical baseline, bukan migration SQL final. Normalisasi, indeks, tipe field, dan partisi perlu ditinjau setelah volume, kebutuhan query, dan provider dipilih.

12.1 Entitas utama

Entitas / tabel konseptual	Tujuan	Kunci dan batasan penting
users / identities	Identitas akun customer dan staff	Gunakan ID internal stabil; jangan menyimpan password mentah; email unik sesuai normalisasi.
roles, permissions, user_roles, role_permissions	RBAC	Unique constraints; perubahan role admin diaudit.
customers, customer_profiles	Data customer terpilah	Batasi PII; consent/preferences terpisah dari transaksi.
addresses	Alamat pengguna	Alamat yang dipilih disalin ke order snapshot.
categories, category_closure (opsional)	Taksonomi produk	Slug unik; parent tidak boleh membentuk siklus.
products	Master produk	Status draft/published/archived; tidak menghapus record yang direferensikan order.
product_variants, skus	Varian dan SKU	SKU unik; variant attributes tervalidasi; stok terhubung pada SKU + location.
product_media, product_attributes	Media dan atribut	Alt text, urutan, file metadata, access control untuk file privat.
price_entries / price_history	Harga dan histori	Currency; validity window; audit perubahan; tidak menulis ulang snapshot order.
inventory_locations	Gudang/toko	Kode unik; aktif/nonaktif; timezone bila dibutuhkan.
inventory_balances	Ringkasan stok per SKU/location	Unique sku+location; update atomik; tidak menggantikan movement ledger.
inventory_movements	Ledger gerakan stok	Immutable append-style; quantity delta, reason, ref type/id, actor.
stock_reservations	Reservasi stok sementara	Expires_at; status; idempotent release/consume; unique relation ke order line bila perlu.
carts, cart_items	Cart guest/customer	Cart token hashed; merge policy; cleanup TTL.

Entitas / tabel konseptual	Tujuan	Kunci dan batasan penting
promotions, coupons, coupon_redemptions	Aturan promo dan pemakaian	Usage cap atomik; start/end; stacking rules; customer eligibility.
orders, order_items	Order dan line snapshots	Money snapshots, address snapshot, currency, unique order number.
order_events / order_timeline	Histori transisi	Append-only untuk audit bisnis; actor/source/reason/timestamp.
payment_attempts	Siklus pembayaran	Provider ref unik sesuai scope; amount/currency; status dan idempotency key.
payment_webhook_events	Dedup dan audit event provider	Unique provider+event_id; payload minimal/redacted; processing state.
refunds / refund_attempts	Pengembalian dana	Amount <= refundable; provider ref; separate status lifecycle.
shipments, shipment_items, tracking_events	Fulfillment dan tracking	Carrier ref, tracking number, state mapping, event dedup.
returns, return_items, return_events	Otorisasi dan proses retur	Order line relation; reason; approved qty; inspection; resolution.
reviews, review_moderation	Rating dan ulasan	Eligibility/purchase link; moderation status; anti-abuse.
wishlists, wishlist_items	Simpan produk	Unique user/product/variant sesuai desain.
cms_pages, cms_revisions, assets	Konten dan revisi	Published version immutable/traceable; draft dan live version dipisah.
support_tickets, ticket_messages	Dukungan pelanggan	Access rules; redaction; file attachment policy.
notifications, notification_outbox	Pengiriman komunikasi	Template/version/channel/status/retry; consent check untuk marketing.
audit_logs	Trail tindakan istimewa	Append-only policy; actor, action, target, reason, request ID, timestamp.
integration_outbox / job_runs	Reliable async effects	State, retry count, next run, idempotency, last error redacted.
consent_records / privacy_requests	Preferensi dan hak data	Purpose, source, policy version, timestamp, workflow status.

12.2 Field contoh untuk order

Field	Tipe konseptual	Aturan
id	UUID / internal ID	Primary key yang tidak dipakai sebagai rahasia publik.
order_number	String yang dapat dibaca	Unique, tidak mudah berurutan bila dapat disalahgunakan untuk enumerasi.
customer_id	Nullable FK	Nullable untuk guest; akses guest memakai verifikasi/token terpisah.
status	Enum / constrained text	Transisi hanya lewat domain command.
currency	Kode ISO mata uang	Wajib disimpan.
subtotal_minor, discount_minor, shipping_minor, tax_minor, total_minor	Integer minor units atau tipe decimal yang terkontrol	Validasi total sesuai fungsi pricing; konsisten di semua service.
shipping_address_snapshot	JSON terstruktur / columns	Snapshot minimasi PII; akses dibatasi.
billing_snapshot	JSON terstruktur / columns	Disimpan bila bisnis dan provider memang memerlukan.
payment_status	Derived/normalized state	Tidak disamakan begitu saja dengan order status; sumber dari payment domain.
created_at, updated_at, paid_at, shipped_at, delivered_at	Timestamp UTC	Jangan timpa event timestamp asli; simpan event timeline.
source / campaign attribution	Structured fields	Jangan menyimpan data analytics yang tidak dibutuhkan di transaksi.
policy_version / consent references	FK atau version ID	Menautkan terms/policy yang diterima saat transaksi.

12.3 Integritas, indeks, dan retensi data

- Gunakan foreign keys dan unique constraints untuk invariant yang harus selalu benar, bukan hanya validasi aplikasi.
- Indeks berdasarkan query nyata: order_number, customer_id + created_at, status + created_at, SKU, slug, provider reference, inventory sku/location.
- Gunakan pagination berbasis cursor untuk dataset besar dan stabilitas saat data berubah.
- Audit immutable atau append-only sebisa mungkin; koreksi dilakukan dengan event kompensasi, bukan menghapus jejak.
- Jadwal retensi ditetapkan per kategori: transaksi, audit, log, marketing events, file upload, dan backup mempunyai kebutuhan berbeda.
- Proses data deletion/anonymization harus mempertahankan rekaman yang wajib disimpan secara hukum/akuntansi, berdasarkan review hukum yang relevan.

13. Keamanan, privasi, dan kepatuhan Indonesia

Bagian ini menetapkan baseline engineering dan daftar verifikasi. Applicability hukum bergantung pada badan usaha, model penjualan, data yang diproses, peran vendor, dan cara pembayaran dijalankan; validasi final perlu dilakukan dengan penasihat hukum dan pihak penyedia berizin.

13.1 Security baseline

Area	Kontrol minimum	Bukti pengujian
Authentication	MFA admin; secure password/reset flow; session revocation; rate limits.	Test login abuse, reset token expiry, session invalidation, MFA bypass attempts.
Authorization	Server-side permission checks; ownership checks; default-deny; role separation.	Negative tests pada setiap objek customer/order dan endpoint admin.
Input / output	Schema validation, output encoding, parameterized queries, file type/size checks.	SAST, DAST, malicious input tests, upload abuse tests.
Secrets	Secret manager/environment secrets, rotation, least access, no secrets in logs/repo.	Secret scanning, deployment config review, rotation drill.
Web security	TLS, secure cookies, CSRF/origin policy, CSP and security headers.	Header scan, cross-origin tests, session/cookie inspection.
Abuse controls	Rate limits, anti-automation controls proportionate to risk, alerting on suspicious patterns.	Login, coupon, checkout, refund, search and webhook abuse scenarios.
Logging / audit	Structured logs with redaction; auditable sensitive actions; correlation IDs.	Check logs for PII/token leakage and verify audit completeness.
Dependencies / supply chain	Pinned/managed dependencies, patch policy, CI scans, protected branches.	Dependency audit, build reproducibility, CI policy review.
Backup / recovery	Encrypted backups, restricted access, restore tests, documented RPO/RTO.	Restore drill using representative database and files.

13.2 Payment-data boundary

- Pilih provider yang sesuai dan lakukan due diligence terhadap status perizinan, kontrak, metode pembayaran, refund, settlement, SLA, dan support.
- Gunakan hosted checkout atau tokenized payment elements bila tersedia; jangan menyimpan PAN/CVV atau data kartu sensitif di database, logs, analytics, atau support tools.
- Kurangi scope card-data environment dengan menjaga jalur checkout tidak menerima atau memproses data kartu mentah bila arsitektur provider memungkinkan.
- Validasi ruang lingkup PCI DSS dengan acquirer/provider dan pihak yang kompeten; penggunaan pihak ketiga tidak otomatis menghapus semua tanggung jawab merchant.
- Jangan menyatakan “PCI compliant” hanya karena memakai provider. Simpan bukti tanggung jawab, konfigurasi, dan penilaian yang berlaku untuk model integrasi.

PCI Security Standards Council menyediakan PCI DSS v4.0.1 pada document library resmi [R5]. Versi dan applicability perlu dikonfirmasi saat memilih metode integrasi dan pihak acquirer/provider.

13.3 Privasi dan pelindungan data

- Buat data inventory: data apa dikumpulkan, tujuan, dasar pemrosesan yang sesuai, sumber, penerima/vendor, lokasi pemrosesan, retensi, serta kontrol akses.
- Kumpulkan hanya data yang dibutuhkan; pisahkan data transaksi dari profil marketing; jangan menjadikan consent marketing sebagai syarat transaksi kecuali ada dasar yang benar.
- Sediakan privacy notice yang jelas, prosedur permintaan akses/koreksi/penghapusan sesuai hak dan pengecualian yang berlaku, serta escalation path untuk insiden.
- Definisikan data processor/controller roles dalam kontrak vendor, kewajiban keamanan, subprocessor, lokasi penyimpanan, transfer lintas batas jika ada, dan bantuan pemenuhan permintaan subjek data.
- Buat incident response workflow: triage, contain, preserve evidence, assess impact, internal escalation, dan penilaian kewajiban notifikasi berdasar hukum aktual.
- Masking PII pada admin/list/log; ekspor data harus dibatasi, memiliki alasan, tercatat, dan link unduhan kedaluwarsa.
- Jangan memasukkan data pribadi pelanggan ke prompt AI, log eksternal, atau analytics tanpa dasar, minimasi, dan kontrol vendor yang disetujui.

13.4 Regulasi Indonesia yang harus diverifikasi

Referensi	Implikasi untuk proyek	Tindakan spesifik
PP 80/2019 tentang Perdagangan Melalui Sistem Elektronik [R1]	Baseline regulasi PMSE untuk transaksi, informasi dan kewajiban pelaku sesuai lingkup.	Tinjau kewajiban informasi, bukti transaksi, penanganan keluhan, kontrak, dan pascatransaksi yang relevan.
Permendag 19/2026 tentang Penyelenggaraan Usaha PMSE [R2]	Halaman resmi Kemendag mencatat berlaku dan mencabut Permendag 31/2023.	Baca teks penuh dan petakan kewajiban yang berlaku ke model single-merchant; jangan memakai Permendag 31/2023 sebagai aturan terkini.
UU 27/2022 tentang Pelindungan Data Pribadi [R3]	Mengatur pemrosesan data pribadi dan kewajiban terkait sesuai peran/konteks.	Buat data map, privacy notice, proses hak subjek data, retensi, vendor review, dan incident response.
Pendaftaran PSE Lingkup Privat [R4]	Portal resmi Komdigi menyatakan layanan e-commerce termasuk kriteria yang perlu ditelaah untuk pendaftaran.	Validasi NIB/KBLI, kewajiban pendaftaran dan detail pengoperasian melalui OSS/Komdigi untuk entitas aktual.
Aturan sistem pembayaran BI dan QRIS [R6]	Penyedia jasa pembayaran tunduk pada izin/pengaturan; merchant perlu menggunakan provider yang sesuai.	Verifikasi status izin provider, kontrak, metode yang didukung, settlement, refund, dan perubahan aturan terbaru.
PCI DSS v4.0.1 [R5]	Standar industri untuk proteksi data pemegang kartu saat relevan.	Tentukan scope dengan acquirer/provider dan pihak yang berwenang; hindari menyimpan data kartu mentah.

Penting tentang kepatuhan

Daftar ini adalah checklist engineering dan due diligence, bukan opini hukum final. Sebelum peluncuran, legal/compliance harus memeriksa naskah regulasi, aturan turunan, klasifikasi kegiatan, kontrak vendor, dan kewajiban yang berlaku tepat pada tanggal operasi.

14. Non-functional requirements dan SLO

Non-functional requirements harus dapat diuji dan dipantau. Nilai target di bawah adalah starting point untuk MVP dengan volume awal yang moderat; sesuaikan setelah load test dan business risk review.

ID	Kategori	Requirement / target awal	Catatan verifikasi
NFR-01	Performance	LCP <= 2.5 s, INP < 200 ms, CLS < 0.1 pada persentil ke-75.	Ukur data field dan synthetic; prioritaskan landing, category, product, cart.
NFR-02	API	p95 response < 400 ms untuk read internal sederhana; < 700 ms untuk write internal.	Kecualikan latensi vendor eksternal; uji cold/warm cache.
NFR-03	Availability	Sasaran storefront 99.9% bulanan bila secara operasional layak.	Tentukan definisi downtime dan maintenance window.
NFR-04	Capacity	Load test untuk baseline forecast + headroom yang disepakati.	Uji traffic spike, campaign peak, dan competing stock purchase.
NFR-05	Security	Tidak ada critical/high finding terbuka yang tidak diterima secara formal saat go-live.	Risk acceptance harus punya owner, expiry, dan kompensasi.
NFR-06	Accessibility	Target WCAG 2.2 AA untuk pola inti sejauh dapat diterapkan.	Automated scan ditambah keyboard/manual review.
NFR-07	Privacy	Data minimization, role-limited access, retention and deletion workflows.	Audit data exports, logs, analytics, and vendor access.
NFR-08	Resilience	Retry aman, idempotent side effects, dead-letter/exception handling.	Chaos/failure tests untuk payment/shipping/email API.
NFR-09	Maintainability	Typed domain contracts, lint/typecheck, code review, migration discipline.	Required CI checks on every pull request.
NFR-10	Portability	Configuration externalized; documented deployment and backup/restore procedures.	Fresh environment can be provisioned from repo and secure secrets.
NFR-11	Observability	Request IDs, logs, metrics, alerts, provider status visibility.	Alert runbook identifies owner and first-response action.
NFR-12	Compatibility	Test latest supported Chrome/Safari/Firefox/Edge and common mobile browsers.	Maintain an explicit browser support matrix.

14.1 Security and quality gates

- Build gagal jika typecheck, lint, required unit/integration tests atau migration checks gagal.
- Critical/high vulnerability: stop release atau documented risk exception oleh owner berwenang dengan expiry date.
- Tidak ada credentials, private keys, payment secrets, session token atau PII pelanggan di public repository/log artifacts.
- Dependency, container/build artefact, and secret scanning dijalankan pada CI yang disetujui.
- Release produksi memiliki artifact/version, migration plan, rollback strategy, and smoke test evidence.

15. SEO, aksesibilitas, dan kualitas UX

E-commerce bergantung pada halaman produk yang dapat ditemukan, jelas, cepat, dan dapat digunakan oleh banyak pola input. SEO bukan pengganti kualitas katalog, dan aksesibilitas bukan pekerjaan setelah desain selesai.

15.1 SEO teknis & konten

- Server-render konten produk penting termasuk nama, harga, availability, deskripsi utama, dan structured data ketika sesuai.
- Bangun Product/ProductGroup/Offer markup secara konsisten dengan data halaman; validasi markup, jangan membuat review/rating palsu.
- Implementasikan canonical URL, sitemap XML, robots directives, breadcrumbs, redirects 301 untuk slug berubah, serta 404 yang benar.
- Jangan index hasil pencarian internal, session URLs, cart, checkout, account, atau query permutations tanpa alasan SEO yang disetujui.
- Produk yang out-of-stock mengikuti policy yang konsisten: tetap tampil dengan status jelas atau redirect/archive bila benar-benar hilang.
- Gunakan image alt yang deskriptif, nama file yang wajar, ukuran/responsiveness yang tepat, dan optimasi delivery.
- Siapkan landing kategori dengan teks bermanfaat; hindari thin pages, duplicate descriptions, dan programmatic pages tanpa nilai pengguna.

Google Search Central mendokumentasikan structured data Product, merchant listings, dan data produk e-commerce. Implementasi dapat meningkatkan eligibility untuk rich appearances, tetapi tidak menjamin tampilan khusus atau ranking. [R8]

15.2 UX dan aksesibilitas

- Semua interaksi utama dapat dijalankan via keyboard; focus indicator terlihat dan urutan fokus masuk akal.
- Form memiliki label, pesan error yang dapat dibaca assistive technology, dan tidak hanya mengandalkan warna.
- Dialog/modal mengelola focus trap, focus return, Escape behavior, dan accessible name.
- Kontras teks dan kontrol, ukuran target sentuh, zoom, reflow, reduced motion, dan validasi inline ditinjau terhadap WCAG 2.2.
- Gunakan skeleton saat membantu persepsi loading; jangan menggeser layout saat gambar atau badge muncul.
- Checkout menghindari pengulangan input, memperlihatkan error dekat field, dan mempertahankan input yang valid saat submission gagal.
- Microcopy membedakan estimasi dari janji pasti; tampilkan biaya dan syarat sebelum pelanggan menekan tombol pembayaran.

W3C merekomendasikan penggunaan versi WCAG terbaru yang sesuai; WCAG 2.2 adalah rekomendasi W3C yang menambah kriteria di atas versi sebelumnya. [R9]

16. Analytics, event taxonomy, dan reporting

Analytics harus mendukung keputusan bisnis sekaligus menghormati privasi. Domain event untuk transaksi dipisah dari analytics pemasaran agar sistem tetap konsisten walau analytics vendor tidak tersedia.

16.1 Event inti

Event	Kapan terjadi	Property minimum yang disarankan
view_item_list	Daftar produk tampil	list_id, category_id, result_count, source_page.
select_item	Produk dipilih dari list	product_id, variant_id bila sudah dipilih, list_id.
view_item	Halaman produk dimuat	product_id, category_id, price/currency hanya sesuai kebijakan analytics.
search	Pencarian dikirim	query term bila diperbolehkan, result_count, filter state.
add_to_cart / remove_from_cart	Item berubah pada cart	product_id, variant_id, quantity, currency, value.
begin_checkout	Checkout dimulai	cart value, item count, currency, customer type (guest/account).
add_shipping_info	Metode pengiriman dipilih	service code, quoted cost, region category (minimized).
add_payment_info	Metode pembayaran dipilih	payment method category; jangan kirim PAN atau secret.
purchase	Order confirmed according to definition	transaction_id pseudonymous, value, tax/shipping/discount, currency, items.
refund	Refund confirmed	transaction reference pseudonymous, amount, currency, reason category.
support_contact	Pelanggan membuka kontak/tiket	topic category, order state; jangan kirim body PII by default.

16.2 Definisi laporan

- Revenue harus didefinisikan: gross merchandise value, net sales setelah diskon, apakah pajak/ongkir termasuk, dan bagaimana refund/chargebacks mengurangi angka.
- Conversion rate mendefinisikan numerator/denominator, attribution window, session/customer uniqueness, dan timezone.
- Payment success rate dihitung berdasarkan payment attempts terminal; tampilkan juga breakdown provider/method/error class.
- Stockout rate, oversell rate, order cancellation rate, on-time dispatch, return rate, refund latency, and ticket rate dipakai untuk operasi.
- Data dashboard menunjukkan updated_at/data freshness dan filter yang aktif; stale metrics tidak boleh tampil seolah realtime.
- Akses export disesuaikan role; data personal dilindungi; export besar berjalan secara asinkron dengan tautan unduhan berakhir.

17. Strategi testing dan acceptance criteria

Testing harus mengikuti risiko domain. Harga, stok, pembayaran, otorisasi, retur, dan retry event layak mendapat cakupan lebih tinggi daripada elemen dekoratif.

17.1 Piramida testing

Lapisan	Cakupan	Kapan dijalankan
Unit tests	Pricing, coupon eligibility, rounding, order transition rules, stock availability, refund cap.	Pada setiap commit/pull request.
Integration tests	Database transactions/constraints, RLS/permissions, payment adapter mocks, webhook dedup, job retries.	CI dan sebelum release.
Contract tests	Request/response, provider adapter schema, webhook signature/test fixtures, carrier state mapping.	CI dan saat vendor/SDK berubah.
E2E tests	Browse -> cart -> checkout -> payment sandbox -> fulfillment update -> customer tracking.	Setiap release kandidat; subset smoke setelah deploy.
Performance tests	Hot product traffic, concurrent stock purchase, checkout load, search, campaign surge.	Sebelum launch dan setelah perubahan arsitektur besar.
Security tests	Access control, injection, XSS, CSRF, IDOR, abuse, file upload, secrets, webhook spoofing.	Setiap milestone; independent review sebelum launch.
Recovery tests	Database restore, object storage restore, payment reconciliation, rollback and queue replay.	Sebelum go-live dan berkala.

17.2 Acceptance test yang wajib

ID	Skenario	Lulus bila
AT-01	Produk draft/archived diakses melalui URL langsung.	Tidak ditampilkan secara publik; admin/editor yang berhak dapat preview sesuai izin.
AT-02	Dua pelanggan membeli SKU terakhir pada waktu hampir bersamaan.	Stok tidak menjadi negatif; hanya transaksi valid yang mendapat stok.
AT-03	Klien memodifikasi harga/discount/total request.	Server mengabaikan angka tidak tepercaya dan menghitung ulang dari sumber kebenaran.
AT-04	Provider mengirim webhook payment sukses dua kali.	Payment tidak diproses dua kali; order, stock, email dan financial ledger konsisten.
AT-05	Browser return URL menyatakan sukses tetapi provider belum mengonfirmasi.	Order tidak dianggap paid sampai verifikasi server-side sesuai kontrak provider.
AT-06	Webhook sukses datang setelah order dibatalkan atau event gagal datang terlambat.	Domain melakukan reconciliation/exception handling; tidak membuat fulfilment/refund yang salah.
AT-07	User A mencoba membaca order User B dengan mengganti ID.	Permintaan ditolak; tidak ada data B yang bocor.
AT-08	Refund parsial pada order dengan diskon kupon.	Refund memakai alokasi diskon yang terdokumentasi; total refund tidak melebihi refundable amount.
AT-09	Shipping API timeout saat checkout.	Pengguna diberi pilihan retry/fallback yang jelas; tidak ada order ganda.
AT-10	Job email atau ERP gagal sementara.	Order tetap valid; job di-retry; kegagalan terminal terpantau dan dapat di-replay.
AT-11	Admin menyesuaikan stok atau membuat refund besar.	Permission, reason, approval sesuai ambang, dan audit trail tercatat.
AT-12	Customer meminta penghapusan/koreksi data.	Request masuk workflow; identitas diverifikasi; pengecualian legal dipertimbangkan; hasil ditelusuri.
AT-13	Campaign berakhir tepat pada batas waktu.	Pricing server mengikuti timezone/boundary yang didefinisikan dan tes deterministik.
AT-14	Produk memiliki banyak foto dan jaringan lambat.	Layout stabil, gambar responsif, error gambar tidak merusak fungsi pembelian.
AT-15	Restore database dan file storage pada environment terisolasi.	Dokumentasi runbook berhasil, data relasi valid, dan transaksi terakhir sesuai RPO yang ditetapkan.

17.3 Test data dan quality guardrails

- Gunakan synthetic customers, addresses, products, cards/provider sandbox tokens; jangan memakai PII produksi untuk testing tanpa dasar dan proteksi.
- Jangan membiarkan test menghubungi provider live atau mengirim email/pesan nyata tanpa explicit test configuration.
- Gunakan deterministic clocks atau controllable time untuk test expiration promo, reservation TTL, dan token expiry.
- Setiap bug produksi yang berdampak pada pembayaran, stok, privacy atau authorization mendapat regression test sebelum ditutup.
- Punya seed data minimal yang merepresentasikan variant, product out-of-stock, promo, order partial, refund, and shipping exception.

18. Deployment, observability, backup, dan operasi

Production readiness meliputi orang, prosedur, akses, supplier, dan recovery - bukan hanya build yang berhasil di platform hosting.

18.1 Lingkungan

Environment	Tujuan	Aturan
Local	Pengembangan individual	Mock provider; .env lokal tidak masuk repository; seed data synthetic.
CI	Validasi otomatis	Typecheck, lint, unit/integration tests, migration checks, secret/dependency scan.
Staging	Verifikasi integrasi dan release candidate	Provider sandbox; data synthetic; akses terbatas; production-like config.
Production	Transaksi aktual	Secrets terpisah; restricted access; monitored deployment; backup dan rollback.

18.2 Deployment workflow

1. Pull request dengan issue/reason, perubahan schema, risks, tests, migration notes, screenshots bila UI berubah, dan rollback considerations.
2. CI memvalidasi format, lint, typecheck, test suite, build, dependency/secrets scan, serta memastikan environment config wajib ada.
3. Review dan merge ke protected branch; deploy ke staging dan jalankan smoke/integration tests yang relevan.
4. Migration dilakukan dengan strategi compatible/expand-contract jika perlu; jangan menggabungkan perubahan yang mengharuskan downtime tanpa rencana.
5. Production rollout memakai canary/gradual rollout jika platform mendukung atau release window yang disetujui; monitor checkout, payment, error rate, dan latency.
6. Jika gate gagal, hentikan rollout atau rollback versi aplikasi; database migration harus punya strategi kompatibilitas/forward-fix.

18.3 Monitoring dan alert

Signal	Alert condition awal	Tindakan pertama
Checkout conversion	Drop abnormal relatif baseline + traffic normal	Pisahkan traffic mix, browser errors, shipping quote, and payment failure.
Payment exceptions	Payment pending/success mismatch atau webhook failures melewati ambang	Check provider dashboard/status, webhook queue, then reconcile safely.
Stock anomalies	Negative stock, oversell, reservation tidak expired	Stop affected SKU checkout if necessary; review concurrency and jobs.
Latency/error	p95/p99 atau 5xx melampaui threshold berkelanjutan	Check recent deploy, DB pool, external dependencies, logs with request ID.
Queue backlog	Oldest job age atau retry count melewati batas	Inspect dependency, rate limits, dead-letter and replay policy.

Signal	Alert condition awal	Tindakan pertama
Security event	Burst login failures, privilege change, suspicious exports	Rate-limit/revoke session/investigate with incident runbook.
Backup/restore	Backup missing/failure atau restore drill failed	Escalate; fix retention/storage/access; re-run verification.

18.4 Backup dan pemulihan

- Back up database dan object storage yang dibutuhkan untuk memulihkan relasi dengan konsisten; simpan encryption keys dan secrets dengan prosedur terpisah yang aman.
- Tentukan backup frequency, retention, encryption, geography, access list, and deletion lifecycle.
- Lakukan restore drill ke environment terisolasi; verifikasi data counts, foreign keys, file access, order consistency, dan waktu pemulihan.
- Dokumentasikan runbook untuk provider outage, credential rotation, malicious admin/session compromise, data corruption, and failed release.
- Simpan kontak escalation vendor, status page, kontrak SLA, dan escalation IDs di sistem dokumentasi yang dapat diakses ketika sistem utama gagal.

19. Roadmap implementasi dan tim

Roadmap berikut adalah estimasi awal untuk tim kecil yang telah berpengalaman dan memakai layanan terkelola. Durasi aktual tergantung kesiapan konten, legal/vendor onboarding, integrasi kurir/pembayaran, dan level polish yang dituntut.

19.1 Fase delivery

Fase	Rentang ilustratif	Output	Gate sebelum lanjut
0. Discovery	1-2 minggu	Model bisnis, scope, personas, mapping policies, vendor shortlist, wireframes, architecture decisions.	Owner menyetujui scope dan asumsi; legal/vendor risks memiliki owner.
1. Foundation	2-3 minggu	Repo/CI, design tokens, auth/RBAC, database/migrations, audit/logging skeleton, staging.	Protected deploy works; permission design ditinjau; tests berjalan.
2. Catalog & storefront	2-3 minggu	Product/category/variant, media, category/product pages, search basics, CMS essentials, SEO.	Catalog and mobile UX accepted; structured data and accessibility checks.
3. Cart & checkout	2-4 minggu	Cart, price engine, shipping quote, order create, payment sandbox, webhook handling.	AT-02 to AT-06 pass; reconciliation path works.
4. Operations	2-4 minggu	Admin order desk, inventory ledger, fulfillment, tracking, returns, notifications.	Ops team can process normal and exception flows.
5. Launch hardening	2-3 minggu	Security review, load tests, backups/restore, privacy/legal review, dashboards, runbooks.	No unresolved critical blocker; restore and incident drills documented.

Beberapa fase berjalan paralel. Kisaran ini bukan janji deadline: untuk 4-6 orang full-time dengan scope MVP jelas, jadikan sekitar 10-19 minggu sebagai rentang planning awal; perluasan ke ERP, multi-warehouse matang, marketplace, data warehouse atau fraud automation dapat menambah durasi signifikan.

19.2 Peran minimal

Peran	Tanggung jawab	Kebutuhan keterlibatan
Product owner / business lead	Keputusan scope, prioritas, kebijakan, acceptance, KPI.	Terlibat aktif tiap minggu; keputusan tidak boleh menggantung.
Tech lead / architect	Boundaries, data design, security trade-offs, code review, release design.	Aktif sepanjang build.
Frontend/full-stack engineer	Storefront, admin UX, API integration, accessibility, performance.	2+ tergantung kompleksitas.
Backend/data engineer	Commerce domain, DB transactions, provider adapters, queue, reconciliation.	1-2; payment/inventory tidak boleh hanya sekadar prototipe.
QA / test engineer	Acceptance, test design, automation, regression, release evidence.	Mulai dari discovery; bukan hanya di akhir.

Peran	Tanggung jawab	Kebutuhan keterlibatan
Design/UX	Flows, interaction states, system tokens, mobile accessibility.	Intensif di awal dan setiap fitur besar.
Security/legal/compliance	Threat model, data map, applicable regulation, provider/contract review.	Milestone-based; wajib sebelum go-live.
Operations/content owner	Catalog quality, fulfilment procedures, support scripts, incident ownership.	Sebelum UAT dan selama soft launch.

19.3 Definition of Ready untuk fitur

- Problem/user dan hasil bisnis terdefinisi; owner dan priority diketahui.
- Acceptance criteria tertulis termasuk error/edge states dan izin akses.
- Data model/API/provider dependencies diketahui; migration dan backfill plan jika perlu.
- Security/privacy impact serta telemetry/logging yang dibutuhkan dipahami.
- Design mencakup loading, error, empty, success, mobile, accessibility, dan permission denied states.

19.4 Definition of Done untuk fitur

- Behavior sesuai acceptance criteria; UI bukan mock untuk aksi yang diklaim tersedia.
- Tests sesuai risiko lulus; negative authorization tests tersedia untuk objek privat/privileged actions.
- Analytics/audit/monitoring masuk sesuai spesifikasi; tidak ada PII atau secret berlebihan di logs.
- Dokumentasi runbook/API/policy diperbarui; feature flags/configuration memiliki default aman.
- Code review selesai; CI lulus; staging evidence dan rollback considerations dicatat.

20. Risiko utama dan mitigasi

Risiko berikut perlu masuk risk register proyek dan ditinjau pada setiap milestone. Severity harus dikalibrasi dengan dampak ke uang, pelanggan, hukum, dan kontinuitas usaha.

Risiko	Dampak	Mitigasi yang diwajibkan	Owner
Harga/order total dimanipulasi	Kerugian finansial dan dispute.	Server-side pricing; immutable snapshots; tamper tests; audit promotion rules.	Tech lead / Commerce
Overselling saat campaign	Pembatalan massal, trust turun.	Atomic stock reservation/update, load tests, safety stock, queue monitoring.	Inventory / Backend
Webhook duplicate/missing	Order ganda atau status salah.	Signature verification, event dedup, idempotency, provider status inquiry, reconciliation.	Payments
Credential/account takeover	Fraud, data leak, admin abuse.	MFA, rate limits, least privilege, alerting, session revocation, recovery drills.	Security / Identity
Vendor outage	Checkout/fulfillment terhenti.	Timeouts, circuit/fallback strategy where suitable, status visibility, manual fallback, provider SLA.	Operations
Data breach / PII leakage	Risiko hukum dan reputasi.	Data minimization, masking, access logs, vendor review, incident response, secure exports.	Privacy / Security
Promo stacking bug	Margin erosion dan abuse.	Single price engine, test matrix, eligibility ledger, budget/usage constraints.	Commerce / Marketing
Stok/finance mismatch	Laporan tidak dapat dipercaya.	Inventory ledger, payment/refund reconciliation, monthly close procedure.	Operations / Finance
Scope creep	Proyek terlambat dan kualitas inti turun.	P0/P1/P2 gating, written change control, acceptance criteria, defer non-core features.	Product owner
Legal requirement overlooked	Operasi melanggar kewajiban yang berlaku.	Review legal terjadwal, current regulation register, documented sign-off.	Legal / Business owner
Backup tidak dapat dipulihkan	Downtime panjang atau data hilang.	Restore test, RPO/RTO, protected backups, independent access and runbook.	Platform / Operations

21. Go-live checklist dan definisi selesai

Peluncuran hanya dilakukan setelah transaksi ujung-ke-ujung, penanganan exception, security, customer support, dan pemulihan diuji. “Berhasil deploy” bukan sinonim dari “siap beroperasi”.

21.1 Produk dan konten

- Semua produk awal memiliki judul, deskripsi, SKU, varian, harga, stok, foto, alt text, kebijakan, dan kategori yang tervalidasi.
- Shipping fees/regions, cut-off times, payment methods, return policy, customer support hours, dan terms jelas.
- Halaman 404/500, unavailable product, no results, cart empty, payment failure, cancellation, return, dan support states diuji.
- SEO: metadata, canonicals, redirects, sitemap, robots, structured data, and Search Console access dikonfigurasi.

21.2 Transaksi dan operasi

- Sandbox/UAT pass untuk payment success, failure, pending/timeout, duplicate webhook, refund, and reconciliation.
- Stok concurrency test lulus; reserved stock expired/released; cycle count dan manual adjustment memiliki audit.
- Order fulfillment, shipment update, tracking, cancellation, partial shipment (jika didukung), returns, and refund berjalan end-to-end.
- CS/gudang/finance memiliki runbook dan akses minimal; test operator dapat menyelesaikan alur normal dan exception.
- Alert queue/payment/stock/order failures sudah diuji, bukan sekadar dibuat.

21.3 Security, privacy, platform

- Admin MFA, least privilege, session revocation, backup restore, secrets rotation plan, and deploy rollback diverifikasi.
- Tidak ada critical/high security defect tanpa risk acceptance formal; dependency/secret scans selesai.
- Privacy notice, terms, data inventory, retention policy, request workflow, vendor contract checks, and applicable PSE/legal checks diselesaikan.
- Status provider, contact escalation, rate limits, log redaction, and incident response contacts terdokumentasi.
- Test data production-safe; public bucket/access policies ditinjau; no secret/service-role keys exposed client-side.
- Soft launch dengan cohort terbatas atau controlled traffic; metrik payment, errors, inventory, conversion, and support dipantau.

21.4 Kriteria sign-off

Sign-off	Pihak yang harus menyetujui	Bukti
Product/business	Product owner / business owner	Acceptance tests, policy/content review, KPI baseline, scope statement.
Technical	Tech lead	Architecture review, CI green, deployment rollback, operational runbooks.
Security/privacy	Security owner + privacy/legal reviewer	Security report, data map, access review, open risk register, privacy procedures.
Payments/finance	Finance/business owner + payment provider contact as needed	Settlement/refund tests, mismatch reconciliation, provider readiness.
Operations	Warehouse/fulfillment + customer support lead	SOPs, shipment/return workflows, alert ownership, staffing and escalation.

22. Glosarium dan referensi resmi

Referensi berikut digunakan sebagai titik awal. Peraturan, standar, provider documentation, and contractual obligations can change; check official sources again before launch and record the exact versions that were reviewed.

22.1 Glosarium

Istilah	Definisi ringkas
B2C	Business-to-consumer: merchant menjual langsung kepada pelanggan akhir.
SKU	Stock Keeping Unit: identitas item/varian yang dikelola untuk stok.
Idempotency	Sifat operasi yang ketika diulang dengan key yang sama tidak menggandakan efek bisnis.
Webhook	Notifikasi server-to-server dari vendor ke aplikasi mengenai event.
Reconciliation	Mencocokkan status/nominal internal dengan sumber provider atau catatan eksternal.
Ledger	Histori pergerakan/entry yang dapat ditelusuri; koreksi dibuat melalui entry baru.
RLS	Row-Level Security: kontrol akses ke baris data pada database, bukan pengganti desain authorization menyeluruh.
RPO	Recovery Point Objective: toleransi maksimum kehilangan data yang ditargetkan saat recovery.
RTO	Recovery Time Objective: target waktu untuk memulihkan layanan/data.
SLO	Service Level Objective: target terukur untuk kualitas layanan.
PCI DSS	Payment Card Industry Data Security Standard; relevansi bergantung pada alur dan scope pemrosesan data kartu.
PSE Lingkup Privat	Penyelenggara Sistem Elektronik lingkup privat; kriteria dan kewajibannya perlu dinilai terhadap entitas/sistem aktual.
PMSE	Perdagangan Melalui Sistem Elektronik.

22.2 Daftar sumber resmi

[R1] PP Nomor 80 Tahun 2019 tentang Perdagangan Melalui Sistem Elektronik - JDIH BPK RI
https://peraturan.bpk.go.id/Details/126143/pp-no-80-tahun-2019
Status yang ditampilkan pada halaman resmi: berlaku; tetap verifikasi perubahan/peraturan turunan.

[R2] Permendag Nomor 19 Tahun 2026 tentang Penyelenggaraan Usaha Perdagangan Melalui Sistem Elektronik - JDIH Kemendag
https://jdih.kemendag.go.id/peraturan/peraturan-menteri-perdagangan-republik-indonesia-nomor-19-tahun-2026-tentang-penyelenggaraan-usaha-perdagangan-melalui-sistem-elektronik-1
Halaman resmi mencatat berlaku, ditetapkan 4 Juni 2026 dan diundangkan 8 Juni 2026; mencabut Permendag 31/2023.

[R3] UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi - JDIH BPK RI
https://peraturan.bpk.go.id/Details/229798/uu-no-27-
Halaman resmi mencatat status berlaku; perhatikan putusan/interpretasi yang relevan dan aturan pelaksana.

[R4] Pendaftaran PSE Lingkup Privat - portal resmi Komdigi
https://pse.komdigi.go.id/tentang-kami
Gunakan kriteria dan panduan terbaru; konfirmasikan proses melalui OSS/Komdigi untuk badan usaha aktual.

[R5] PCI Security Standards Council - Document Library, termasuk PCI DSS v4.0.1
https://www.pcisecuritystandards.org/document_library/
Penetapan scope dan validasi harus merujuk pada acquirer/provider dan pihak kompeten.

[R6] Bank Indonesia - QRIS dan informasi perizinan sistem pembayaran
https://www.bi.go.id/id/fungsi-utama/sistem-pembayaran/ritel/kanal-layanan/qris/default.aspx
Untuk metode pembayaran, cek ketentuan BI, status izin provider, perjanjian, dan ketentuan yang berlaku saat integrasi.

[R7] Google Search Central - Core Web Vitals
https://developers.google.com/search/docs/appearance/core-web-vitals?hl=id
Referensi target performa pengalaman pengguna pada field data.

[R8] Google Search Central - Merchant listing structured data
https://developers.google.com/search/docs/appearance/structured-data/merchant-listing?hl=id
Panduan data terstruktur produk, harga, stok, pengiriman, dan retur untuk eligibility di Search.

[R9] W3C - Web Content Accessibility Guidelines (WCAG) 2.2
https://www.w3.org/TR/WCAG/
Gunakan kriteria yang relevan dan catat metode penilaian manual/otomatis.

[R10] OWASP Top 10 2025
https://owasp.org/www-project-top-ten/
Dokumen awareness tentang risiko aplikasi web penting; lengkapi dengan verification/testing framework.

[R11] OWASP Application Security Verification Standard (ASVS) - versi 5.0.0
https://owasp.org/projects/asvs
Pilih versi baseline, catat requirement IDs yang dipakai dalam security test plan.

[R12] Bank Indonesia - informasi Perizinan Penyelenggara Jasa Sistem Pembayaran
https://www.bi.go.id/id/fungsi-utama/sistem-pembayaran/perizinan/default.aspx
Verifikasi status perizinan penyedia pembayaran yang relevan sebelum integrasi.

Penutup: keputusan yang perlu dikunci sebelum implementasi

- Tipe bisnis dan katalog: barang fisik/digital, ukuran katalog, kompleksitas varian, dan aturan produk yang dibatasi.
- Payment provider dan shipping provider: kemampuan API, sandbox, webhook, refund, settlement, biaya, SLA, support, dan kontrak.
- Operasi: jumlah gudang, stock source of truth, cut-off, retur, peran operator, maker-checker, dan customer support coverage.
- Kepatuhan: badan usaha, izin/registrasi, privacy roles, data residency/transfer, consumer terms, recordkeeping, dan tax treatment.
- Target bisnis: traffic forecast, peak campaign, conversion baseline, availability expectations, budget, ownership, dan launch date.

Prinsip akhir

Versi pertama harus unggul pada kebenaran transaksi, kejelasan UX, auditability, recovery, dan disiplin scope. AI, microservices, serta ratusan menu admin tidak memperbaiki commerce core yang belum akurat.